

AnyDB CMS

One CMS for every database

Design Documentation

Draft — October 2026

Abstract

AnyDB CMS is a database-agnostic CMS and admin layer. It connects to SQL, document, key-value and realtime databases, including cloud-hosted ones such as Firebase, Supabase, Neon, MongoDB Atlas, AWS, Google Cloud and Azure, and gives every client stack one REST/GraphQL API and one admin UI.

Status: design phase. This document describes what to build and why. Nothing described here is implemented yet. “anydbcms” is a working name; check domain, package scope and trademark before committing. Time and file-count figures are planning estimates, not benchmarks.

Contents

1	Overview	4
1.1	Problem	4
1.2	Product	4
1.3	Users	4
1.4	Scope	4
1.5	Principles	5
2	What to Build	5
2.1	Components	5
2.2	Adapter families	6
2.3	Per-adapter files	6
2.4	Dependency rules (enforced in CI)	6
2.5	Definition of done for an adapter	6
3	Language Decision	6
3.1	Recommendation	6
3.2	Why TypeScript first	7
3.3	Where TypeScript is weaker	7
3.4	Options compared	7

3.5	Language freedom for adapters	8
4	Architecture	8
4.1	System context	8
4.2	Layers	8
4.3	Read request flow	8
4.4	Connect-and-introspect flow	9
4.5	Capability handling	9
4.6	Multi-tenant bring-your-own-database	9
4.7	Deployment view	9
5	Adapter Contract	9
5.1	Required operations	10
5.2	Capability flags	10
5.3	Mapping rules per family	10
5.4	Error model	10
5.5	Conformance suite	11
5.6	Adding a new adapter	11
6	Data Model and Schemas	11
6.1	Control-plane entities	11
6.2	Canonical content model	11
6.3	Type mapping (canonical to native)	12
6.4	Portable query AST	12
6.5	Rules	13
6.6	Control-plane DDL	13
6.7	Query AST JSON Schema	15
7	Security	16
7.1	Threat model	17
7.2	Credentials	17
7.3	Least privilege	17
7.4	Network controls	17
7.5	Injection defence	18
7.6	Access control, audit and testing	18
8	API	18
8.1	REST endpoints (v1)	18
8.2	Pagination, errors and versioning	19

9 SDKs	19
9.1 Hand-written layer	20
9.2 Rules	20
10 Deployment	20
10.1 Environments and services	20
10.2 Cloud identity and networking	21
10.3 Configuration, observability, CI/CD	21
11 Roadmap	21
11.1 Hand-written files for the MVP (estimate)	22
11.2 Risks	22
A Adapter Protocol (proto)	23
B Architecture Decision Records	24

1 Overview

1.1 Problem

Content tools are tied to one database. Strapi and Directus are SQL-only, FireCMS is Firestore-first, and internal-tool builders such as Retool and Appsmith reach many databases but are not content CMSs. Teams running several stacks end up with several admin panels.

1.2 Product

AnyDB CMS is a database-agnostic CMS and admin layer:

- Connect any supported database, including bring-your-own cloud databases.
- Introspect it, describe it as a canonical content model, and edit it through one admin UI.
- Expose one REST/GraphQL API so every client stack uses the same contract.
- Keep credentials server-side, read-only by default, with a full audit trail.

1.3 Users

User	Needs
Developer	Connect a database, get an API and SDK
Editor	Edit content without touching the database
Admin / security	Control who sees what, rotate credentials, read audit logs
Tenant (multi-tenant mode)	Bring their own database safely

1.4 Scope

In scope for the MVP:

- Adapters: Postgres, MySQL, MongoDB, Firestore, SQL Server, DynamoDB.
- Introspection, content-model overlay, CRUD, cursor pagination.
- RBAC with field and row rules, SSO/OIDC.
- Encrypted credential vault, audit log, SSRF guard.
- REST, GraphQL and OpenAPI; a TypeScript SDK and generated Dart and Python SDKs.
- Admin UI.

Later: Cosmos DB, Spanner, BigQuery, Redshift, Redis, Firebase RTDB, realtime subscriptions across all adapters, gRPC, and adapters in other languages through the adapter protocol.

Non-goals:

- Not a database or migration tool. It reads and writes the customer's database; it does not replace it.
- Not a cross-database transaction manager. Cross-source relations are resolved at the gateway, not made atomic.
- Not a BI or analytics tool. Warehouse adapters (BigQuery, Redshift) are read-only by default.

1.5 Principles

1. **Security first.** Credentials never reach a browser or mobile app.
2. **Honest capabilities.** Each adapter declares what it can and cannot do; the UI follows it.
3. **Adapters are isolated.** One slow or hostile database cannot starve the rest.
4. **One contract.** Clients never talk to a database directly.

2 What to Build

2.1 Components

Component	Purpose	MVP
packages/core	Canonical content model, query AST, capability flags, errors	Yes
protocol/	Language-neutral adapter contract (proto and OpenAPI)	Yes
packages/adapter-sdk	Base adapter, registry, conformance test kit	Yes
packages/adapters/*	One adapter per database	6
packages/vault	Envelope encryption, KMS, key rotation, cloud-identity tokens	Yes
packages/auth	OIDC, RBAC/ABAC, field and row rules	Yes
packages/audit	Append-only audit writer with redaction	Yes
packages/network-guard	SSRF blocklist, TLS rules, egress and tunnels	Yes
apps/api	Gateway: REST, GraphQL, OpenAPI	Yes
apps/worker	Isolated adapter runners, introspection jobs, real-time	Yes
apps/admin	Editor and admin UI	Yes
db/control-plane	Migrations for tenants, connections, metadata, permissions, audit	Yes
sdk-ts	Hand-tuned TypeScript client	Yes
sdk/dart, sdk/python	Generated from OpenAPI plus a small hand-written layer	Yes
infra/	Docker, Terraform, Kubernetes	Yes
tests/	Conformance, security, end-to-end	Yes

2.2 Adapter families

Family	Adapters	Notes
SQL	postgres, mysql, mssql	postgres covers Supabase, Neon, RDS, Aurora, Cloud SQL, AlloyDB, Azure PostgreSQL
Document	mongodb, firestore, cosmosdb	mongodb also covers Atlas, DocumentDB (feature gaps), Cosmos Mongo API
Key-value	dynamodb, redis	Key conditions only; scans are explicit and costly
Realtime	firebase-rtdb	Path-based
Analytics	bigquery, redshift	Read-only by default; later
Other cloud	spanner, athena, opensearch	Later, on demand

2.3 Per-adapter files

Every adapter folder has the same layout, so adding a database is a copy-and-fill job:

```
package.json  tsconfig.json  README.md
src/index.ts  adapter.ts      config.schema.ts  connection.ts  auth.ts
src/introspect.ts  capabilities.ts  query-compiler.ts  type-map.ts
src/operations.ts  pagination.ts   realtime.ts        errors.ts
tests/conformance.test.ts  compiler.test.ts  introspect.test.ts  security.test.ts
```

2.4 Dependency rules (enforced in CI)

- `core` imports nothing internal.
- `adapters/*` depend only on `core` and `adapter-sdk`.
- `admin` talks only to `api` or `sdk-ts`, never to a database.
- Only `api` and `worker` may import `vault`.

2.5 Definition of done for an adapter

1. Passes the shared conformance suite.
2. Passes the security suite (injection, identifier allowlist).
3. Declares accurate capability flags.
4. Documents supported services, auth modes and limits in its README.

3 Language Decision

This is a recommendation based on the project's needs, not a measured benchmark.

3.1 Recommendation

Use **TypeScript for the whole MVP**. Add **Go** later for performance-critical or third-party adapters through the adapter protocol. Dart and Python SDKs are generated from OpenAPI.

Part	Language	Why
core, adapter-sdk, api, worker	TypeScript (Node.js)	One language across server and UI, shared types, strong official SDKs for Firestore, MongoDB, DynamoDB, Postgres
Admin UI	TypeScript, React (Refine)	Backend-agnostic data providers, same types as the API
Control-plane migrations	SQL	Plain and reviewable
SDK: TypeScript	TypeScript	Hand-tuned, first class
SDK: Flutter	Dart	Generated plus a small hand-written layer
SDK: Python	Python	Generated plus a small hand-written layer
Third-party or heavy adapters (later)	Go or any language	Separate process through the protocol

3.2 Why TypeScript first

- The query AST, content model and capability flags are shared by the gateway, adapters, SDK and admin UI. One type system avoids drift.
- Database SDK coverage is best on Node for the targets that matter (Firebase Admin, MongoDB, DynamoDB, pg/mysql2, Azure and Google clients).
- It is the fastest path to a working MVP for one or two engineers.

3.3 Where TypeScript is weaker

- CPU-heavy work and very high connection counts are better in Go or Rust.
- A single event loop needs care: run adapters in worker processes, not inside the API process.

3.4 Options compared

Option	Strength	Weakness	Verdict
TypeScript everywhere	Shared types, fastest MVP, best DB SDK coverage	Weaker for CPU-bound work	MVP choice
Go core	Fast, small binaries, great concurrency	Admin UI still needs TypeScript; two type systems	Good for later adapters
Python core	Rich data libraries	Slower, weaker typing for a gateway	SDK and scripting only
Rust core	Performance and safety	Slow to build, thin cloud-SDK coverage	Not worth it for the MVP
Java / Kotlin	Mature DB drivers	Heavier, slower iteration	Only if a client requires it

3.5 Language freedom for adapters

Adapters run as separate processes speaking the protocol in `adapter.proto`. The gateway does not care what language an adapter is written in. First-party adapters ship in TypeScript and run through the same protocol, with an in-process fast path allowed for trusted ones.

4 Architecture

4.1 System context

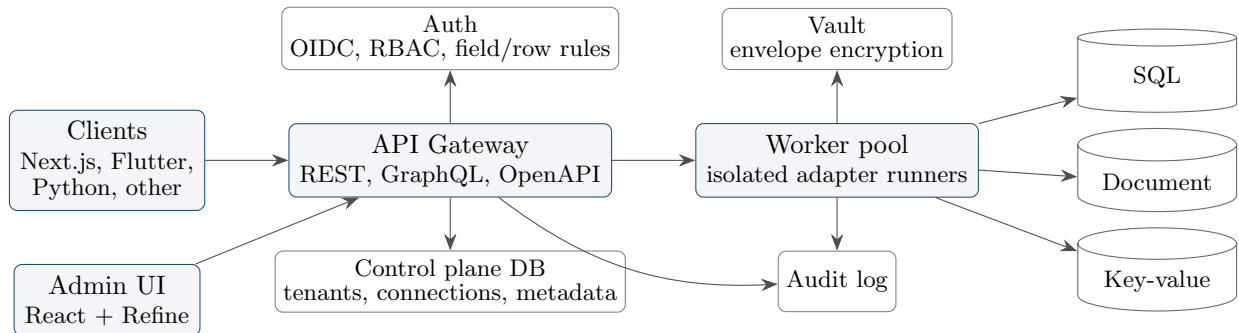


Figure 1: System context. Clients and the admin UI only ever call the gateway.

4.2 Layers

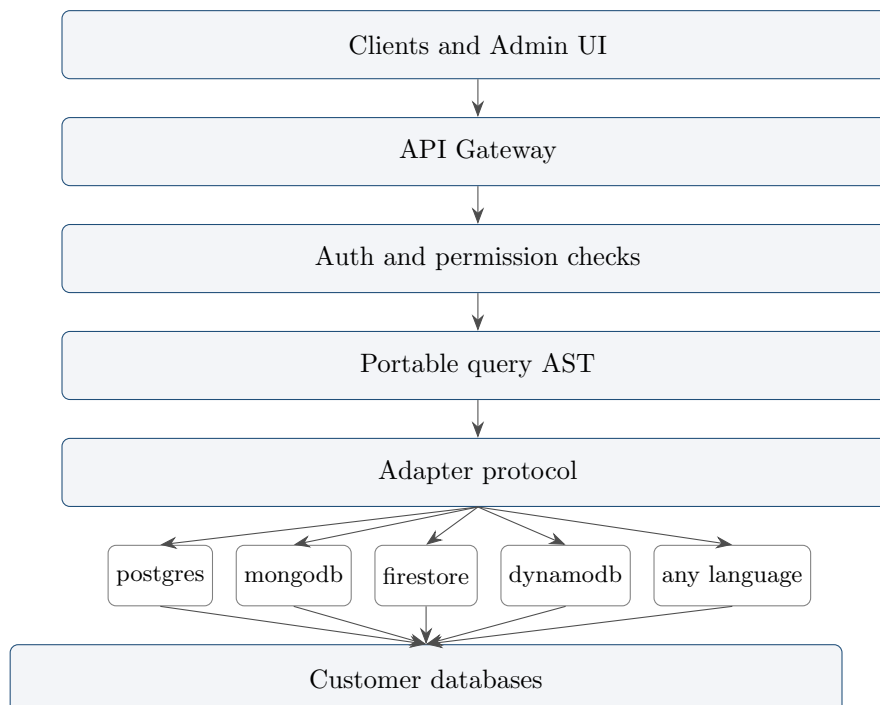


Figure 2: Request path from client to database.

4.3 Read request flow

1. The client calls `GET /v1/connections/{id}/collections/orders/records`.

2. The gateway verifies the token and resolves roles through Auth.
3. The gateway loads connection and collection metadata from the control plane.
4. It builds the query AST and applies field and row rules.
5. It calls `find(ast)` on the worker over the adapter protocol.
6. The worker fetches a short-lived credential or IAM token from the vault.
7. The adapter runs a parameterised native query against the customer database.
8. The worker returns records and a next cursor; the gateway appends an audit event and responds.

4.4 Connect-and-introspect flow

1. An admin posts a new connection (type, host, secret reference).
2. The network guard validates the host (SSRF, TLS, allowlist).
3. The vault encrypts and stores the secret.
4. The control plane saves the connection, read-only by default.
5. A worker reads the catalog or samples documents and saves a draft content model.
6. The admin reviews the draft schema before any collection is exposed.

4.5 Capability handling

When a query uses something an adapter cannot do, the gateway has three outcomes: compile it to the native query (supported), reject it with `CAPABILITY_UNSUPPORTED` (not supported), or emulate it at the gateway and flag it in the response (emulatable). For example, DynamoDB has no arbitrary sort, so sorting by any column is rejected; Firestore has limited OR and inequality filters, so some filters are rejected or emulated and marked as such.

4.6 Multi-tenant bring-your-own-database

The control plane holds tenants, connections, secret references, collection metadata, and roles. The data plane runs one isolated worker per connection (or per tenant). Each connection gets its own pool limits so one tenant's slow query cannot starve another.

4.7 Deployment view

A load balancer with a WAF fronts stateless API pods. API pods use the control-plane Postgres and a job queue. Worker pods read secrets through KMS and reach customer databases through a NAT with static egress IPs, so customers can allowlist the platform. Private networking (PrivateLink, Private Service Connect, Azure Private Link) and SSH tunnels are supported alongside.

5 Adapter Contract

An adapter is the only code that knows a database's native language. It turns the portable query AST into native queries and native results into canonical records.

5.1 Required operations

Operation	Purpose
<code>connect(config)</code>	Open a connection or client using resolved credentials
<code>introspect()</code>	Return collections, fields, types, keys, relations, indexes
<code>capabilities()</code>	Return capability flags
<code>find(query)</code>	List records by filter, sort, projection, cursor
<code>get(collection, id)</code>	Fetch one record
<code>create / update / delete</code>	Write operations (blocked on read-only connections)
<code>batch(ops)</code>	Multiple writes, atomic only if <code>transactions</code> is supported
<code>subscribe(query)</code>	Optional realtime stream
<code>close()</code>	Release resources

5.2 Capability flags

```
interface Capabilities {
  joins: boolean;
  transactions: "none" | "single-document" | "multi-document";
  filters: { or: boolean; inequality: "full" | "single-field" | "none";
    fullText: boolean };
  sort: "any-field" | "indexed-only" | "key-only";
  pagination: { cursor: true; offset: boolean }; // cursor is mandatory
  aggregations: boolean;
  realtime: boolean;
  schema: "enforced" | "inferred";
  writes: boolean;
}
```

The gateway and admin UI use these flags to hide or disable unsupported controls instead of doing silent client-side work.

5.3 Mapping rules per family

Concern	SQL	Document	Key-value
Introspection	Read catalog (<code>information_schema</code>)	Sample documents, infer draft schema	Read key schema, sample items
Filters	Parameterised SQL	Native filter objects	Key conditions only
Pagination	Keyset	<code>startAfter</code> cursor	<code>LastEvaluatedKey</code>
Relations	Foreign keys	Reference fields or embedding	Denormalised
Transactions	Full	Limited	Limited

5.4 Error model

Adapters map native errors to a fixed set so clients see one vocabulary: `CONNECTION_FAILED`, `AUTH_FAILED`, `NOT_FOUND`, `CONFLICT`, `VALIDATION_FAILED`, `CAPABILITY_UNSUPPORTED`, `RATE_LIMITED`, `TIMEOUT`, `READ_ONLY`, `INTERNAL`.

5.5 Conformance suite

A shared test kit runs the same scenarios against every adapter:

1. introspect returns stable collections and field types;
2. create, get, update, delete round trip;
3. cursor pagination returns each record exactly once;
4. unsupported filters return `CAPABILITY_UNSUPPORTED`;
5. a read-only connection rejects writes with `READ_ONLY`;
6. hostile identifiers and operators are rejected (injection);
7. errors map to the standard set.

An adapter is not releasable until all pass.

5.6 Adding a new adapter

Copy the adapter template; fill in the config schema, connection, introspection, query compiler and type map; declare capabilities honestly; register it in the registry; pass the conformance and security suites. Nothing in core, api or admin changes.

6 Data Model and Schemas

Two models exist and must not be mixed. The **control plane** is the platform's own Postgres database (tenants, connections, metadata, permissions, audit). The **canonical content model** is the platform's description of a customer's data; it is stored in the control plane, never inside the customer's database.

6.1 Control-plane entities

6.2 Canonical content model

A **collection** has a name, a native name, fields, relations and capabilities. A **field** has a name, a canonical type, *required* and *unique* flags, validation rules and UI hints. A **relation** has a name, a kind and a mapping to a target collection. Canonical types: string, text, integer, decimal, boolean, datetime, date, json, array, reference, binary, geopoint.

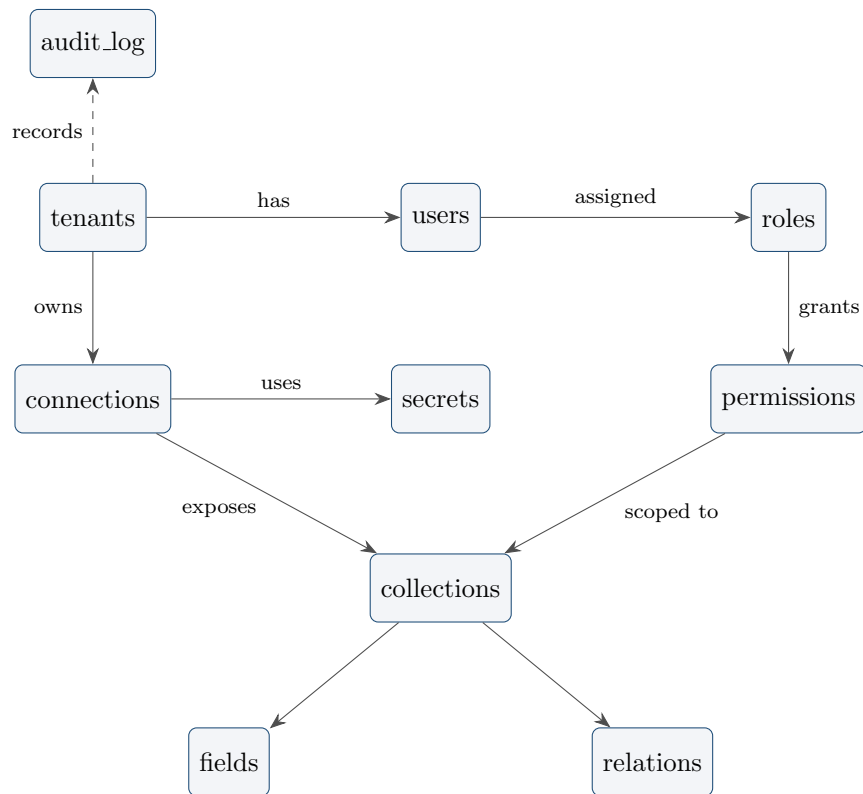


Figure 3: Control-plane entities. The full DDL follows in Section 6.6.

6.3 Type mapping (canonical to native)

Canonical	Postgres	MySQL	MongoDB	Firestore	DynamoDB
string	varchar/text	varchar	string	string	S
integer	int/bigint	int/bigint	int32/int64	integer	N
decimal	numeric	decimal	decimal128	double	N
boolean	boolean	tinyint(1)	bool	boolean	BOOL
datetime	timestamptz	datetime	date	timestamp	S (ISO) or N
json	jsonb	json	object	map	M
array	array or jsonb	json	array	array	L
reference	foreign key	foreign key	ObjectId	document ref	key string
geopoint	point	point	GeoJSON	geopoint	M

Adapters own the exact conversion in `type-map.ts`. Lossy conversions must be flagged during introspection.

6.4 Portable query AST

A query has a collection, an optional filter (and/or/not over comparisons), sort, projection and a page (limit and cursor). Comparison operators: `eq`, `ne`, `lt`, `lte`, `gt`, `gte`, `in`, `nin`, `contains`, `startsWith`, `exists`.

```

{
  "collection": "orders",
  "filter": { "and": [
    { "field": "status", "op": "eq", "value": "paid" },
  ]
}

```

```
{ "field": "total", "op": "gte", "value": 100 }
}],
"sort": [{ "field": "created_at", "dir": "desc" }],
"projection": ["id", "status", "total", "created_at"],
"page": { "limit": 50, "cursor": null }
}
```

Field names are always validated against introspected metadata before compilation; they are never interpolated into native queries.

6.5 Rules

1. Metadata lives in the control plane, never in the customer's database.
2. Cursor pagination is the default everywhere.
3. Cross-source relations resolve at the gateway with batching, not inside any database.
4. Validation happens in the CMS layer for schemaless stores.

6.6 Control-plane DDL

```
-- AnyDB CMS control-plane schema (PostgreSQL)
-- Platform metadata only. Customer data never lives here.

CREATE EXTENSION IF NOT EXISTS pgcrypto;

CREATE TABLE tenants (
    id          uuid PRIMARY KEY DEFAULT gen_random_uuid(),
    name        text NOT NULL,
    created_at  timestampz NOT NULL DEFAULT now()
);

CREATE TABLE users (
    id          uuid PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id   uuid NOT NULL REFERENCES tenants(id) ON DELETE CASCADE,
    email       text NOT NULL,
    oidc_subject text NOT NULL,
    created_at  timestampz NOT NULL DEFAULT now(),
    UNIQUE (tenant_id, email),
    UNIQUE (tenant_id, oidc_subject)
);

-- Encrypted connection secrets (envelope encryption; key reference points to KMS).
CREATE TABLE secrets (
    id          uuid PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id   uuid NOT NULL REFERENCES tenants(id) ON DELETE CASCADE,
    kms_key_ref text NOT NULL,
    ciphertext  bytea NOT NULL,
    auth_kind   text NOT NULL CHECK (auth_kind IN
        ('password', 'service_account', 'iam_token', 'assume_role', 'managed_identity',
        'secret_ref')),
    key_version integer NOT NULL DEFAULT 1,
    created_at  timestampz NOT NULL DEFAULT now(),
    rotated_at  timestampz
);

CREATE TABLE connections (
    id          uuid PRIMARY KEY DEFAULT gen_random_uuid(),
    tenant_id   uuid NOT NULL REFERENCES tenants(id) ON DELETE CASCADE,
    name        text NOT NULL,
```

```

adapter_type text NOT NULL,          -- postgres, mysql, mssql, mongodb, firestore,
dynamodb, ...
config        jsonb NOT NULL DEFAULT '{}':jsonb, -- non-secret settings: host, port, db,
tls, pool caps
secret_id     uuid REFERENCES secrets(id),
mode          text NOT NULL DEFAULT 'read_only' CHECK (mode IN ('read_only','read_write')),
status        text NOT NULL DEFAULT 'pending' CHECK (status IN ('pending','active','error','
disabled')),
created_at    timestampz NOT NULL DEFAULT now(),
updated_at    timestampz NOT NULL DEFAULT now(),
UNIQUE (tenant_id, name)
);

CREATE TABLE collections (
  id            uuid PRIMARY KEY DEFAULT gen_random_uuid(),
  connection_id uuid NOT NULL REFERENCES connections(id) ON DELETE CASCADE,
  native_name   text NOT NULL,
  display_name  text NOT NULL,
  exposed       boolean NOT NULL DEFAULT false, -- nothing exposed until reviewed
  UNIQUE (connection_id, native_name)
);

CREATE TABLE fields (
  id            uuid PRIMARY KEY DEFAULT gen_random_uuid(),
  collection_id uuid NOT NULL REFERENCES collections(id) ON DELETE CASCADE,
  native_name   text NOT NULL,
  canonical_type text NOT NULL CHECK (canonical_type IN
    ('string','text','integer','decimal','boolean','datetime','date',
    'json','array','reference','binary','geopoint')),
  required      boolean NOT NULL DEFAULT false,
  is_primary_key boolean NOT NULL DEFAULT false,
  validation     jsonb NOT NULL DEFAULT '{}':jsonb,
  ui             jsonb NOT NULL DEFAULT '{}':jsonb,
  lossy          boolean NOT NULL DEFAULT false, -- native type did not map cleanly
  UNIQUE (collection_id, native_name)
);

CREATE TABLE relations (
  id            uuid PRIMARY KEY DEFAULT gen_random_uuid(),
  source_collection_id uuid NOT NULL REFERENCES collections(id) ON DELETE CASCADE,
  target_collection_id uuid NOT NULL REFERENCES collections(id) ON DELETE CASCADE,
  name          text NOT NULL,
  kind          text NOT NULL CHECK (kind IN ('one_to_one','one_to_many','many_to_one',
'many_to_many')),
  mapping        jsonb NOT NULL,          -- which fields join, or reference path
  UNIQUE (source_collection_id, name)
);

CREATE TABLE roles (
  id            uuid PRIMARY KEY DEFAULT gen_random_uuid(),
  tenant_id     uuid NOT NULL REFERENCES tenants(id) ON DELETE CASCADE,
  name          text NOT NULL,
  UNIQUE (tenant_id, name)
);

CREATE TABLE user_roles (
  user_id      uuid NOT NULL REFERENCES users(id) ON DELETE CASCADE,
  role_id      uuid NOT NULL REFERENCES roles(id) ON DELETE CASCADE,
  PRIMARY KEY (user_id, role_id)
);

CREATE TABLE permissions (
  id            uuid PRIMARY KEY DEFAULT gen_random_uuid(),
  role_id       uuid NOT NULL REFERENCES roles(id) ON DELETE CASCADE,

```

```

    collection_id    uuid NOT NULL REFERENCES collections(id) ON DELETE CASCADE,
    action           text NOT NULL CHECK (action IN ('read','create','update','delete')),
    field_rules      jsonb NOT NULL DEFAULT '{}':jsonb,    -- hide / mask / read-only per field
    row_filter       jsonb,                                -- portable filter AST applied to every
    query
    UNIQUE (role_id, collection_id, action)
);

-- Append-only audit log.
CREATE TABLE audit_log (
    id                bigint GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    tenant_id        uuid NOT NULL REFERENCES tenants(id),
    actor_id         uuid REFERENCES users(id),
    connection_id    uuid,
    collection        text,
    record_id        text,
    operation         text NOT NULL,                      -- read, create, update, delete, connection.create,
    diff             jsonb,                                -- redacted before/after
    ip               inet,
    request_id       text,
    at               timestampz NOT NULL DEFAULT now()
);

CREATE INDEX audit_log_tenant_time ON audit_log (tenant_id, at DESC);
CREATE INDEX connections_tenant ON connections (tenant_id);
CREATE INDEX collections_connection ON collections (connection_id);

-- Make the audit log append-only for the application role.
-- (Run as owner; replace app_role with the real application role.)
-- REVOKE UPDATE, DELETE, TRUNCATE ON audit_log FROM app_role;

-- Optional: row-level security so a request can only see its own tenant.
-- ALTER TABLE connections ENABLE ROW LEVEL SECURITY;
-- CREATE POLICY tenant_isolation ON connections
-- USING (tenant_id = current_setting('app.tenant_id')::uuid);

```

6.7 Query AST JSON Schema

```

{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "$id": "https://anydbcms.dev/schemas/query-ast.schema.json",
  "title": "AnyDB CMS portable query AST",
  "type": "object",
  "required": ["collection"],
  "additionalProperties": false,
  "properties": {
    "collection": { "type": "string", "minLength": 1 },
    "filter": { "$ref": "#/$defs/filter" },
    "sort": {
      "type": "array",
      "items": {
        "type": "object",
        "required": ["field"],
        "additionalProperties": false,
        "properties": {
          "field": { "type": "string" },
          "dir": { "enum": ["asc", "desc"], "default": "asc" }
        }
      }
    },
    "projection": { "type": "array", "items": { "type": "string" } },
  },
}

```

```

    "page": {
      "type": "object",
      "additionalProperties": false,
      "properties": {
        "limit": { "type": "integer", "minimum": 1, "maximum": 500, "default": 50 },
        "cursor": { "type": ["string", "null"] }
      }
    },
    "$defs": {
      "filter": {
        "oneOf": [
          { "$ref": "#/$defs/comparison" },
          {
            "type": "object", "required": ["and"], "additionalProperties": false,
            "properties": { "and": { "type": "array", "minItems": 1, "items": { "$ref": "#/$defs/filter" } } }
          },
          {
            "type": "object", "required": ["or"], "additionalProperties": false,
            "properties": { "or": { "type": "array", "minItems": 1, "items": { "$ref": "#/$defs/filter" } } }
          },
          {
            "type": "object", "required": ["not"], "additionalProperties": false,
            "properties": { "not": { "$ref": "#/$defs/filter" } }
          }
        ]
      },
      "comparison": {
        "type": "object",
        "required": ["field", "op"],
        "additionalProperties": false,
        "properties": {
          "field": { "type": "string" },
          "op": {
            "enum": ["eq", "ne", "lt", "lte", "gt", "gte", "in", "nin",
                    "contains", "startsWith", "exists"]
          },
          "value": {}
        }
      }
    }
  }
}

```

7 Security

Security drives the architecture. This section lists the controls the MVP must have.

7.1 Threat model

Threat	Control
Stolen credentials from the control plane	Envelope encryption; key held in KMS, not in the database
Credentials leaking to clients	Clients only call the API; secrets never leave the vault
SSRF through bring-your-own-database hosts	Block private ranges and metadata endpoints unless explicitly configured
Query injection	Parameterised queries, identifier allowlist from introspected metadata, operator allowlist
Over-broad database access	Dedicated least-privilege role, read-only by default
Cross-tenant impact	Isolated workers, per-connection pool and rate limits
Unaccountable changes	Append-only audit log outside tenant databases

7.2 Credentials

- Encrypt connection secrets with a data key wrapped by a KMS key (envelope encryption), with a documented rotation path.
- Back up the key separately from database backups. Losing it makes secrets unrecoverable.
- Prefer identity-based access over stored passwords: AWS IAM database auth, cross-account roles with external ID and Secrets Manager ARNs; Google service accounts, the Cloud SQL connector and IAM database auth; Azure Entra ID tokens and managed identities (tokens expire, so the vault refreshes them).
- Never log secrets. Redact connection strings in errors.

7.3 Least privilege

- Ask tenants for a dedicated CMS role scoped to the needed schemas or tables.
- Connections are **read-only by default**; write mode is an explicit opt-in.
- **Firebase:** the Admin SDK uses a service account with full access and is not gated by Security Rules. Scope the service account with IAM and enforce authorization in the CMS.
- **Supabase:** the service-role key bypasses row-level security. To enforce RLS, forward the editor's JWT or use a dedicated Postgres role.

7.4 Network controls

- Require TLS (**verify-full** where supported); allow custom CA bundles.
- Publish static egress IPs so tenants can allowlist the platform.
- Support SSH tunnels and private networking.
- Resolve and validate hostnames server-side and re-check after DNS resolution to avoid rebinding.

7.5 Injection defence

- Compile the query AST to parameterised queries only.
- Allowlist table and column names against introspected metadata.
- MongoDB: reject operator injection (**\$where**, **\$function**, keys starting with **\$** from user input).
- Firestore and DynamoDB: validate field paths.
- Raw-query features sit behind a separate permission and are always audited.

7.6 Access control, audit and testing

SSO/OIDC for editors and MFA for admins. RBAC at collection level plus field rules (hide, mask, read-only) and row filters, enforced in the gateway independently of database grants. The audit log is append-only and stored in the control plane; it records actor, tenant, connection, collection, record id, operation, a redacted diff, IP and timestamp, and also logs connection changes, credential reads by workers and permission changes.

The security test suite covers SQL and NoSQL injection, identifier allowlist bypass, SSRF (private IPs, metadata IPs, DNS rebinding), permission bypass, secret leakage in logs and errors, and cross-tenant access. CI generates an SBOM, pins dependencies and scans them on every pull request.

8 API

One contract for every client. REST is the primary surface; GraphQL is generated from the same content model; OpenAPI is the source for SDK generation.

8.1 REST endpoints (v1)

Method	Path	Purpose
POST	/v1/connections	Create a connection (read-only by default)
GET	/v1/connections	List connections
GET	/v1/connections/{id}	Connection detail and health
PATCH	/v1/connections/{id}	Update config, mode, secret reference
DELETE	/v1/connections/{id}	Remove connection and secret
POST	/v1/connections/{id}/introspect	Start an introspection job
GET	/v1/connections/{id}/collections	List collections and fields
PATCH	/v1/collections/{id}	Edit display name, UI hints, exposure
GET	/v1/connections/{id}/collections/{name}/records	List records

Method	Path	Purpose
GET	.../records/{rid}	Get one record
POST	.../records	Create
PATCH	.../records/{rid}	Update
DELETE	.../records/{rid}	Delete
POST	/v1/connections/{id}/batch	Batch writes
GET	/v1/audit	Query the audit log
GET	/v1/health	Liveness and readiness

Write endpoints return `READ_ONLY` on read-only connections.

8.2 Pagination, errors and versioning

Pagination is cursor-only. Cursors are opaque, signed and bound to the query, so a client cannot alter the filter between pages. Offset pagination is offered only where the adapter supports it. Responses carry `capabilityNotes` listing any emulated or degraded behaviour.

Error code	HTTP	Meaning
VALIDATION_FAILED	400	Invalid input
AUTH_FAILED	401	Missing or invalid token
FORBIDDEN, READ_ONLY	403	Not permitted
NOT_FOUND	404	Unknown resource
CONFLICT	409	Write conflict
CAPABILITY_UNSUPPORTED	422	Adapter cannot do this
RATE_LIMITED	429	Too many requests
CONNECTION_FAILED	502	Database unreachable
TIMEOUT	504	Database timed out
INTERNAL	500	Unexpected error

The API is path-versioned (`/v1`); additive changes do not bump the version. Authentication uses a bearer token from the OIDC provider; service tokens are tenant- and role-scoped, rotatable and never accepted from browsers. Writes accept an `Idempotency-Key` header, and rate limits apply per tenant and per connection.

9 SDKs

Every client stack uses the same API. SDKs are generated from `openapi.yaml` so they never drift, with a small hand-written layer for ergonomics.

Language	Package	Approach	
TypeScript / JavaScript	@anydbcms/sdk	Hand-tuned, first class	
Dart / Flutter	anydbcms (pub.dev)	Generated models plus hand-written client	Check
Python	anydbcms (PyPI)	Generated models plus hand-written client	
Kotlin / Java, Swift	generated	Android, JVM, iOS	
Go, C#, PHP, Ruby, Rust	generated	On demand	

package names on npm, pub.dev and PyPI before committing to them.

9.1 Hand-written layer

Each first-party SDK adds the same small set of behaviours: a *client* (base URL, token, request pipeline), *auth* (token refresh), a *query builder* in the language’s idiom, *pagination* as an async iterator over cursors, optional *realtime* helpers, and typed *errors* from the API error codes.

9.2 Rules

1. SDKs never hold database credentials. They only hold API tokens.
2. Browser and mobile SDKs use short-lived user tokens, never service tokens.
3. CI regenerates SDKs on every API release and fails if generated code is out of date.
4. Semantic versioning follows the API version.

10 Deployment

10.1 Environments and services

Service	Scaling	Notes	
api	Horizontal, stateless	Never connects to customer databases directly	Environments
worker	Horizontal, per-connection pool caps	Only component that decrypts secrets	
admin	Static assets	Talks only to the API	
control-plane DB	Managed Postgres	Backups, point-in-time recovery	
queue	Managed	Introspection jobs, realtime fan-out	

local (`docker compose` with api, worker, admin, control-plane Postgres and test databases), *staging* (full stack, synthetic tenant data) and *production* (Kubernetes, managed Postgres, KMS-backed secrets).

10.2 Cloud identity and networking

Cloud	Identity (avoid stored passwords)	Private networking
AWS	IAM database auth, cross-account role with external ID, Secrets Manager ARN	PrivateLink, VPC peering
Google Cloud	Service accounts, Cloud SQL connector, IAM database auth	Private Service Connect
Azure	Entra ID tokens, managed identities (refreshed by the vault)	Private Link
Any	Passwords in the vault, SSH tunnels	Static egress IPs

10.3 Configuration, observability, CI/CD

Configuration uses environment variables (names only, never committed values): `DATABASE_URL`, `KMS_KEY_REF`, `OIDC_ISSUER`, `OIDC_CLIENT_ID`, `SESSION_SECRET_REF`, `EGRESS_BLOCKLIST_EXTRA`, `WORKER_MAX_POOL_PER_CONNECTION`, `LOG_LEVEL`. In production, secrets come from a secrets manager, not from `.env` files.

Observability: structured logs with request ids and secrets redacted at the logger; per-connection metrics for latency, errors, pool usage and rate-limit hits; alerts on failed introspection, credential refresh failures and unusual audit patterns.

The CI/CD pipeline runs lint, type-check and unit tests; the conformance suite per adapter against containerised databases; the security suite; image builds with SBOM and dependency scanning; SDK regeneration with drift checks; then deploys to staging, runs end-to-end tests and promotes.

Control-plane backups use automated backups and point-in-time recovery. The KMS key is backed up separately; without it, stored secrets cannot be decrypted even from an intact backup. Run a key-rotation drill before launch.

11 Roadmap

Estimates assume one or two engineers and are rough planning guesses, not benchmarks.

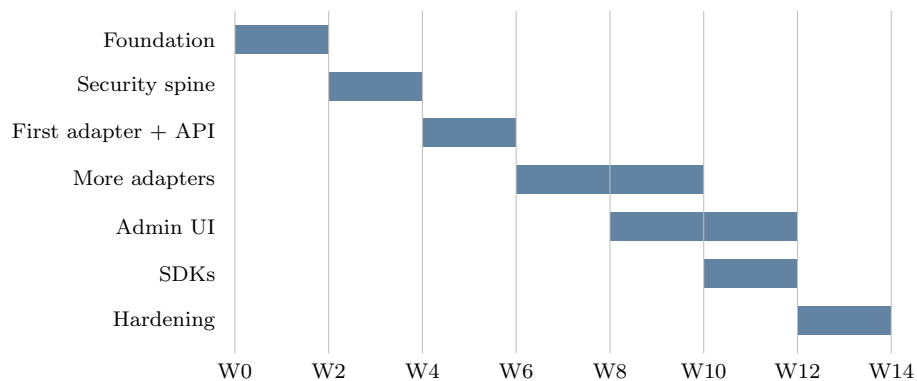


Figure 4: MVP plan in weeks.

Phase	Goal	Exit criteria
1. Foundation	Repo, core types, adapter protocol, control-plane schema	core builds; migrations apply cleanly
2. Security spine	Vault, auth, audit, network guard	Secrets encrypted end to end; SSRF tests pass
3. First path	Postgres adapter plus API	Conformance suite green on Postgres
4. More adapters	MongoDB, Firestore, MySQL, SQL Server, DynamoDB	Each passes conformance and security suites
5. Admin UI	Connect, introspect, edit, permissions	An editor completes a full content edit through the UI only
6. SDKs	Generated Dart and Python, hand-tuned TypeScript	Sample apps (Next.js, Flutter, FastAPI) run
7. Hardening	Load, security review, docs, cloud identity	Security review and key-rotation drill done

11.1 Hand-written files for the MVP (estimate)

Area	Files	Area	Files
Root config	12	api	25
core	15	worker	12
protocol + adapter-sdk	13	admin	40
6 adapters	36	control-plane DB	10
vault	8	sdk-ts	8
auth	10	Dart SDK	8
audit + network-guard	11	Python SDK	9
infra	15	adapter templates (Go, Python)	16
tests	20	CI + docs	20
Total (approximate)			288

11.2 Risks

Risk	Mitigation
Capability gaps make some databases feel second class	Honest capability flags; clear UI messaging
Credential handling mistakes	Security spine before any adapter; key-rotation drill
Scope creep across databases	Ship six adapters; add others on demand
Driver or ORM version changes (for example Prisma and MongoDB)	No single ORM for all stores; isolate drivers inside adapters
Licensing of embedded tools	Prefer MIT/Apache components; legal review before embedding source-available tools

A Adapter Protocol (proto)

```
// AnyDB CMS adapter protocol.
// An adapter implements this service in any language. The gateway calls it.
syntax = "proto3";

package anydbcms.adapter.v1;

import "google/protobuf/struct.proto";

service Adapter {
  rpc Connect(ConnectRequest) returns (ConnectResponse);
  rpc Introspect(IntrospectRequest) returns (IntrospectResponse);
  rpc Capabilities(CapabilitiesRequest) returns (CapabilitiesResponse);
  rpc Find(FindRequest) returns (FindResponse);
  rpc Get(GetRequest) returns (GetResponse);
  rpc Create(CreateRequest) returns (CreateResponse);
  rpc Update(UpdateRequest) returns (UpdateResponse);
  rpc Delete(DeleteRequest) returns (DeleteResponse);
  rpc Batch(BatchRequest) returns (BatchResponse);
  rpc Subscribe(FindRequest) returns (stream ChangeEvent); // optional
  rpc Close(CloseRequest) returns (CloseResponse);
}

// Credentials are resolved by the worker and passed in memory only; never logged.
message ConnectRequest {
  string connection_id = 1;
  string adapter_type = 2;
  google.protobuf.Struct config = 3;
  google.protobuf.Struct credentials = 4;
  bool read_only = 5;
}

message ConnectResponse { bool ok = 1; Error error = 2; }

message IntrospectRequest { string connection_id = 1; }
message IntrospectResponse {
  repeated CollectionInfo collections = 1;
  Error error = 2;
}

message CollectionInfo {
  string native_name = 1;
  repeated FieldInfo fields = 2;
  repeated RelationInfo relations = 3;
}

message FieldInfo {
  string native_name = 1;
  string native_type = 2;
  string canonical_type = 3;
  bool required = 4;
  bool is_primary_key = 5;
  bool lossy = 6;
}

message RelationInfo {
  string name = 1;
  string target = 2;
  string kind = 3;
  google.protobuf.Struct mapping = 4;
}

message CapabilitiesRequest { string connection_id = 1; }
message CapabilitiesResponse {
  bool joins = 1;
  string transactions = 2; // none | single-document | multi-document
  bool filter_or = 3;
}
```

```

string filter_inequality = 4; // full | single-field | none
bool full_text = 5;
string sort = 6;             // any-field | indexed-only | key-only
bool offset_pagination = 7;  // cursor pagination is mandatory
bool aggregations = 8;
bool realtime = 9;
string schema = 10;          // enforced | inferred
bool writes = 11;
}

message FindRequest {
  string connection_id = 1;
  google.protobuf.Struct query = 2; // portable query AST (see query-ast.schema.json)
}
message FindResponse {
  repeated google.protobuf.Struct records = 1;
  string next_cursor = 2;
  repeated string capability_notes = 3;
  Error error = 4;
}

message GetRequest { string connection_id = 1; string collection = 2; string id = 3; }
message GetResponse { google.protobuf.Struct record = 1; Error error = 2; }

message WriteRequest {
  string connection_id = 1;
  string collection = 2;
  string id = 3; // empty on create
  google.protobuf.Struct values = 4;
}
message WriteResponse { google.protobuf.Struct record = 1; Error error = 2; }

message DeleteRequest { string connection_id = 1; string collection = 2; string id = 3; }
message DeleteResponse { bool ok = 1; Error error = 2; }

message BatchRequest { string connection_id = 1; repeated WriteRequest writes = 2; bool atomic = 3; }
message BatchResponse { repeated WriteResponse results = 1; Error error = 2; }

message ChangeEvent {
  string type = 1; // insert | update | delete
  google.protobuf.Struct record = 2;
}

message CloseRequest { string connection_id = 1; }
message CloseResponse { bool ok = 1; }

message Error {
  string code = 1; // CONNECTION_FAILED, AUTH_FAILED, NOT_FOUND, CONFLICT, VALIDATION_FAILED,
                  // CAPABILITY_UNSUPPORTED, RATE_LIMITED, TIMEOUT, READ_ONLY, INTERNAL
  string message = 2;
  google.protobuf.Struct details = 3;
}

```

B Architecture Decision Records

ADR 0001: Language choice

Proposed, 2026-10-08

Decision: TypeScript for core, adapter-sdk, first-party adapters, api, worker and admin; generated Dart and Python SDKs; adapters in any language through a language-neutral protocol. **Revisit when** worker CPU or connection counts become the bottleneck, or a customer needs an adapter

whose best driver is not on Node.

ADR 0002: Adapters as processes behind a protocol

Proposed, 2026-10-08

Decision: define the adapter contract in `adapter.proto` and run adapters as separate worker processes, with an in-process fast path for trusted first-party adapters. **Gains:** any language, per-connection isolation, one conformance kit. **Costs:** a network hop and more services to operate.

ADR 0003: CMS metadata lives in the control plane

Proposed, 2026-10-08

Decision: store all CMS metadata in a separate control-plane Postgres; customer databases hold only customer data; connections are read-only by default. **Cost:** schema drift must be caught by re-introspection and reconciled with stored metadata.